GOOGLE CLOUD ZERO-TRUST AI SECURITY & ISO/IEC 42001 AIMS GOVERNANCE PLATFORM

Aseguramiento, Gobernanza y Auditoría Continua de IA

Plataforma integral para evaluar, auditar y blindar arquitecturas de Inteligencia Artificial Empresarial (GenAI, LLMs, Agentes Autónomos, MCP y RAG) bajo estándares mundiales **OWASP AI-SVS v1.0 (Nivel L2/L3)** e **ISO/IEC 42001:2023**.

OWASP AI-SVS V1.0 (12 CAPÍTULOS) ISO/IEC 42001:2023 AIMS MODEL GARDEN Y MODEL ARMOR (FASE 3) VERTEX AI GEMINI 3.8 FLASH (ADC SIN LLAVES)

VERTEX EVALUATION AUTOSXS (FASE 4) MODEL MONITORING Y SCC AI (FASE 5)

EL PROBLEMA A RESOLVER

El Punto Ciego Crítico en la Adopción Empresarial de GenAI

Las organizaciones despliegan modelos generativos, flujos agénticos, herramientas MCP y pipelines RAG sin verificación arquitectónica ni gobernanza ISO 42001.

⚠ Brechas de Acceso y Despliegue sin Gobierno

Según **IBM Cost of a Data Breach 2025**, el **13% de las organizaciones** sufrió brechas en modelos o aplicaciones de IA, y el **97% de ellas** carecía de controles de acceso adecuados o Evaluación de Impacto (`ISO 42001 A.5.1`).

⚠ Superficie Multi-Turno y Agéntica

Pipelines RAG, servidores MCP y agentes introducen vectores críticos: **Inyección Multi-Turno Crescendo** (`C02.10`), **Envenenamiento Normativo/Vectorial** (`C01.4`) y SSRF/IMDS (`C04.3`).

⚠ Silo entre CISO y Ciencia de Datos

Los equipos de seguridad carecen de herramientas para auditar grafos de agentes, manifiestos MCP (`C10.1`) y ACLs vectoriales (`C08.1`) antes de producción.

Brecha de Gobernanza Operativa (ISO/IEC 42001)

Dificultad para operacionalizar los controles de **ISO/IEC 42001:2023** —como Políticas Corporativas de IA (`A.2.1`), Canal Ético Confidencial (`A.3.3`), Inventario de Activos IA (`A.4.1`) y Apelación Humana (`A.5.2`)— en el ciclo de ingeniería.

Proliferación de "Shadow AI" y Denial of Wallet

Invocaciones externas sin cuotas, comparación insegura de tokens (`C05.3`), cuentas de servicio sobre-privilegiadas (`C05.2`), falta de presupuestos Anti-DoW (`C11.1`) y exposición de logprobs (`C11.4`).

Fuente: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

IMPACTO DE LA INACCIÓN

El Costo Real de Omitir la Auditoría Preventiva de IA

Operar sistemas de IA sin verificación expone a la organización a sanciones financieras, legales y operativas severas.

€35M
o 7% de facturación global anual en multas estatutarias del **EU AI Act Art. 99**

97%
de las apps de IA vulneradas carecían de control de acceso (**IBM 2025**; 13% sufrió brechas)

10 / 10
Chequeos automatizados de **OWASP LLM Top-10** ejecutados por auditoría

148
Controles integrados (AISVS 56, ISO 42001 54, EU AI Act 10, LFPDPPP 14, LFPC 14)

Exfiltración de Secretos, IMDS y PII

Ataques multi-turno crescendo y SSRF diseñados para extraer metadatos cloud (`169.254.169.254`), llaves API o registros entre inquilinos cuando faltan ACLs pre-recuperación (`C08.1`).

Sanciones Regulatorias y Suspensión

Incumplimiento de controles AIMS ISO/IEC 42001, purga en cascada ARCO (LFPDPPP/GDPR) o retracto comercial del Art. 56 LFPC provoca suspensiones y litigios.

Decisiones Algorítmicas Inapelables

Dictámenes alucinados o decisiones automatizadas sesgadas sin canal de apelación humana (`ISO 42001 A.5.2`) ni canal ético (`A.3.3`) erosionan la confianza institucional.

NUESTRA SOLUCIÓN

AegisAI: Aseguramiento Integral y Automatizado de IA

Transformando semanas de auditoría manual en verificación determinística respaldada por evidencia textual y código de remediación.

🛡 Verificación Multi-Estándar Shift-Left

AegisAI inspecciona documentos de arquitectura, PDFs, paquetes ZIP, microservicios y telemetría GCP en vivo contra **OWASP AI-SVS v1.0** e **ISO/IEC 42001:2023** simultáneamente.

- Evaluación Map-Reduce determinística con esquemas enum estrictos por lote (`buildBatchChaptersSchema`).
- Citación textual obligatoria (`textoEvidencia` y `fuenteEvidencia`).
- Enmascaramiento DLP pre-inferencia, Google Cloud Model Armor y bloqueo de inyección multi-turno crescendo (`C02.10`).

⚡ Arquitectura Remediada al 100% y Recetario Completo

Más allá del diagnóstico, AegisAI sintetiza una **Especificación de Arquitectura Corregida Drop-in** (Sección 3, incl. Stack GCP en 3 Fases) más un **Recetario Técnico Completo** (Sección 4).

- Renderiza todos los parches `1..N` sin truncamiento, incluso en auditorías con más de 35 hallazgos.
- Resúmenes por oración completa y detección precisa de lenguaje (`typescript` , `hcl` , `yaml` , `python` , `bash`).
- Exportación ejecutiva en PDF y Markdown lista para comités de certificación e ingeniería.

1. Integridad Criptográfica (C01.4)

Snapshots normativos verificados con manifiesto SHA-256 + procedencia firmada en Model Garden / Registry.

2. GCP Live Scanner sin Llaves (C05.2)

Inspección de solo lectura sobre Vertex AI, Model Armor, AutoSxS, Model Monitoring, SCC AI, Cloud Run e IAM.

3. Telemetría Continua AIMS (C08.4)

Monitoreo en tiempo real de cobertura de citación, fidelidad JSON, AutoSxS y postura de controles.

MATRIZ DE CUMPLIMIENTO

Soporte Multi-Estándar y Gobernanza AIMS ISO/IEC 42001

Evaluación simultánea de estándares técnicos globales de seguridad en IA, sistemas de gestión y leyes de privacidad.

Estándar / Marco	Alcance Técnico y de Gobernanza	Controles Clave Verificados y Aplicados por AegisAI	Nivel
OWASP AI-SVS v1.0	Estándar de Verificación de Seguridad en IA (12 Capítulos)	`C01.4` SHA-256 y Model Garden, `C02.10` Model Armor y Guardia Crescendo, `C04.1` Contenedor Read-Only, `C04.3` Cloud IAP y Bloqueo SSRF, `C05.2–C05.4` Auth en Tiempo Constante e IAM, `C08.1/C08.4` ACLs RAG y AutoSxS, `C09.4` Sagas, `C10.1–C10.5` Seguridad MCP, `C11.1/C11.4` Anti-DoW y Logprobs Off, `C12.2` Alertas SCC AI.	L1 / L2 / L3 LISTO
ISO/IEC 42001:2023	Sistema de Gestión de IA (AIMS Cláusulas 4–10 y Anexo A)	`Cláusula 4.1/4.2` Contexto y Stakeholders, `Cláusula 5/A.2.1/A.2.3` Política Corporativa IA, `A.6.1.2/A.7.3` Model Garden/Registry, `A.6.2.6` Model Armor y Model Monitoring, `Cláusula 9.1/A.6.2.4` Vertex Evaluation (AutoSxS), `A.6.2.8` SCC AI Protection.	CERTIFICACIÓN LISTA
Regulación Mexicana (2026)	Protección al Consumidor (LFPC) y Datos Personales (LFPDPPP)	Transparencia algorítmica, prevención de patrones oscuros, retracto de 5 días (Art. 56 LFPC), purga en cascada ARCO y enmascaramiento DLP.	ESTATUTARIO LOCAL
Marco BYOF Personalizado	*Bring Your Own Framework* (Multi-Inquilino)	Ingesta autenticada por administrador (`C05.3`) con verificación SHA-256 (`C01.4`) y pre-filtrado ACL por dominio de inquilino (`allowedDomains` , `C08.1`).	AISLADO POR TENANT

Motor Map-Reduce Cruzado sin Colisiones: Evalúa más de 103 controles combinados de OWASP AI-SVS e ISO/IEC 42001 en lotes paralelos usando enums de capítulo restringidos para que las Cláusulas 9/10 y Anexo A.9/A.10 jamás colisionen con C09/C10.

ARQUITECTURA DE SOFTWARE

Arquitectura Zero-Trust de 4 Capas y Defensa en Profundidad

Arquitectura serverless endurecida en Google Cloud Run detrás de Identity-Aware Proxy (IAP) con inferencia Vertex AI ADC sin llaves API.

1. Perímetro y SPA

- **Cloud IAP** (`--no-allow-unauthenticated`)
- **React 19 + TS + Vite**
- Lista blanca OAuth 2.0 en Firebase Auth (`google.com` , `altostrat.com`)
- Avisos visibles ISO 42001 de Política, Apelación (`A.5.2`) y Canal Ético (`A.3.3`)

2. API Endurecida y Model Armor

- **Contenedor Read-Only** (`chmod -R a-w /app` , `C04.1`)
- **Google Cloud Model Armor** sanitizando entradas/salidas en línea
- Tokens en tiempo constante (`crypto.timingSafeEqual` , `C05.3`)
- Guardia DNS Rebinding (`C10.5`) y Firma MCP (`C10.1`)
- Cuotas Anti-DoW (`C11.1`)

3. Vertex AI ADC y Multi-LLM

- **Vertex AI** (`gemini-3.8-flash`) vía IAM ADC sin requerir llave API Gemini
- **Model Garden / Registry** con modelos firmados (`C01.4`)
- Motor Multi-Proveedor (Claude, OpenRouter, OpenAI, Local Proxy)
- Detector Multi-Turno Crescendo (`C02.10`) y Logprobs Off (`C11.4`)
- Bloqueo SSRF/IMDS (`C04.3`)

4. Datos, AutoSxS y SCC AI

- **Cloud Firestore** (`aegis-ai-db`) vía Admin SDK (308/308 pruebas)
- **Vertex Evaluation (AutoSxS)** y **Model Monitoring** (skew/drift)
- **Security Command Center (SCC) con Protección AI** en tiempo real
- Manifiesto SHA-256 (`C01.4`) y Sagas Compensatorias (`C09.4`)

Aislamiento Zero-Trust y Alertamiento SCC con Protección AI (C12.2):

El estado en tiempo de ejecución se persiste exclusivamente en Firestore (`system_config/admin_settings`) y caché efímero `/tmp/aegis-runtime-cache` . Cada evento de seguridad (escalación de prompt injection, bloqueo SSRF, fallo de token, exceso de cuota DoW, reversión de saga) emite una alerta JSON estructurada hacia Google Cloud Logging y **Security Command Center (SCC) con Protección AI** para respuesta inmediata del SOC.

CICLO DE VIDA DE PROTECCIÓN IA EN GOOGLE CLOUD (ISO/IEC 42001)

5 Productos Nativos de Seguridad y Gobernanza en las Fases 3, 4 y 5

Cómo AegisAI operacionaliza ISO/IEC 42001:2023 y OWASP AI-SVS v1.0 en Desarrollo, Evaluación y Despliegue Controlado en Producción.

FASE 3 • DESARROLLO Y PROTECCIONES

Diseño de Sistemas AI y Cadena de Suministro

• **Mapa Visual de Brechas:** Genera un mapa visual y basado en evidencia de las brechas entre el estado actual y el deseado (`L1/L2/L3`).
• **Model Garden / Model Registry:** Librería de modelos revisados (Garden) y modelos personales (Registry). Todos los modelos están firmados y verificados por Google y socios, evitando obtener modelos de Internet con posibles puertas traseras (`ISO A.6.1.2 / A.7.3` , `C01.4`).
• **Model Armor:** Se posiciona delante de los LLM. Sanitiza entradas y salidas en tiempo real, detecta y bloquea inyección de prompts y jailbreaks, y filtra contenido tóxico del usuario y de las respuestas por igual (`ISO A.6.2.6` , `C02.10`).

FASE 4 • EVALUACIÓN DE CONTROLES

Revisión de los Controles Aplicados

• **Vertex Evaluation Service (AutoSxS):** Marco integrado en Vertex AI que utiliza **AutoSxS** (categoriza y califica respuestas automáticamente como un maestro calificando la tarea de un alumno).
• **Métricas de Seguridad:** Evalúa discurso de odio, acoso, contenido sexualmente explícito y contenido peligroso.
• **Pista de Auditoría ISO 42001:** Mucho más rápido y económico que la revisión manual por especialistas humanos, proporcionando la pista de auditoría exigida por `ISO/IEC 42001 Cláusula 9.1 y A.6.2.4` (`OWASP C08.4`).

FASE 5 • DESPLIEGUE CONTROLADO

Despliegue Controlado en Producción y SOC

• **Vertex AI Model Monitoring:** Evalúa el rendimiento en producción detectando **sesgo entre entrenamiento y producción** (*training-serving skew*) y **deriva** (*drift*, cuando el mundo cambia y el modelo queda obsoleto), alertando de inmediato si deja de operar con seguridad (`ISO Cláusula 9.1 / A.6.2.6`).
• **Security Command Center (SCC) con Protección AI:** Detección de amenazas y vulnerabilidades integrada con Vertex AI. Si alguien intenta enviar una inyección de prompts, aparece como alerta en tiempo real para que el SOC responda a tiempo (`ISO A.6.2.8 / C12.2`).

Integración en Escáner GCP en Vivo y Blueprint Remediado: El Escáner GCP en Vivo de AegisAI audita estos 5 servicios con tokens OAuth efímeros de solo lectura, y la Sección 3.4 de cada Arquitectura Remediada genera recetas Terraform/TypeScript listas para producción en las 3 fases.

EJECUCIÓN OPERATIVA

Flujo del Auditor: De la Ingesta al Blindaje al 100%

Ciclo determinístico de aseguramiento en 6 etapas con supervisión humana integrada y remediación automatizada.

1 **Ingesta Autenticada y Model Armor Pre-Vuelo**
El usuario corporativo (verificado por Cloud IAP + Firebase ID Token) carga PDFs/ZIPs; Model Armor, `inspectPromptAndTrackSession` (`C02.10`) y DLP sanean la entrada.

2 **Contexto SHA-256 y Procedencia Model Garden**
Se validan los snapshots normativos contra `integrity-manifest.json` (`C01.4`), modelos firmados en Model Garden/Registry y marcos por `tenantDomain` (`C08.1`).

3 **Evaluación Map-Reduce en Vertex AI y AutoSxS**
`gemini-3.8-flash` (ADC sin llaves, `temperature: 0.0` , `responseLogprobs: false`) evalúa cada lote con pista de auditoría Vertex Evaluation (AutoSxS).

4 **Mapa Visual de Brechas y Apelación Humana (A.5.2)**
Gráficos radar interactivos, mapa visual L1/L2/L3 basado en evidencia y flujo directo de Apelación / Revisión Humana (`ai-appeals@aegisai.enterprise`).

5 **Arquitectura Remediada al 100% y Recetario Completo**
Sintetiza la Sección 3 drop-in (incl. Stack GCP de 3 Fases ISO 42001) + Sección 4 Cookbook para todos los hallazgos `1..N` con etiquetas precisas.

6 **Model Monitoring, SCC AI y Saga Compensatoria**
Guardado en Firestore con atribución `ownerUid` (`C05.4`), protección `runCompensatingSaga` (`C09.4`), monitoreo de skew/drift y alertas SCC AI.

ESPECIFICACIONES Y VERIFICACIÓN DEVSECOPS

Benchmarks de Seguridad Verificados y Postura en Producción

Validado continuamente mediante pruebas unitarias de reglas Firestore, suites OWASP AI-SVS y chequeos preflight en Cloud Run.

308/308
Pruebas unitarias de Cloud Firestore Security Rules aprobadas (`projects:test`)

5 GCP AI
Servicios Nativos de Protección ISO 42001 en las Fases 3, 4 y 5

0
Secretos expuestos o roles IAM amplios (`roles/viewer` revocado, `C05.2`)

97.8%
Puntaje Auto-Auditoría (100% ISO 42001 • 94.7% OWASP AI-SVS)

Postura Endurecida en Cloud Run y Stack GCP

- **Contenedor Inmutable (C04.1):** Usuario no-root `aegisuser` con `chmod -R a-w /app`.
- **Perímetro Zero-Trust (C04.3):** Cloud IAP + `--no-allow-unauthenticated` + egreso privado VPC + bloqueo SSRF/IMDS.
- **Stack GCP de 3 Fases:** Model Garden/Registry, Model Armor, Vertex Evaluation (AutoSxS), Model Monitoring y SCC con Protección AI.
- **Protección FinOps Anti-DoW (C11.1):** Límites por usuario de tasa, concurrencia y presupuesto de tokens en 24h.

Vertex AI ADC sin Llaves, Multi-Proveedor y AIMS

- **Vertex AI sin Llaves (Predeterminado):** Conectado a `gemini-3.8-flash` vía IAM ADC sin requerir llave API Gemini.
- **Motor Multi-Proveedor:** Soporta Anthropic Claude, OpenRouter, OpenAI Directo y Proxy Local/Corporativo.
- **SCC AI y Cloud Logging (C12.2):** Alertas en tiempo real (`aegis-security-alerting-c12-2`) para respuesta del SOC.
- **Suite Documental Bilingüe:** 8 Manuales en Inglés y 9 en Español + 3 Presentaciones Ejecutivas/FinOps/Maestra.

TRAZABILIDAD INTEGRAL DE REMEDIACIÓN

Controles OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Implementados

Controles arquitectónicos y de gobernanza aplicados en código, contenedor, perímetro cloud y políticas AIMS.

Controles Técnicos OWASP AI-SVS v1.0 (17 Dominios Endurecidos)

- **C01.4 y C13.1 Cadena de Suministro:** `verifyNormativeSnapshotsIntegrity()` SHA-256 + procedencia firmada en Model Garden / Registry.
- **C02.10 y C07.1 Sanitización en Línea:** Google Cloud Model Armor + `inspectPromptAndTrackSession()` multi-turno (HTTP 422).
- **C04.1 & C04.3 Infraestructura:** `/app` solo lectura (`chmod -R a-w`), Cloud IAP, egreso VPC y bloqueo SSRF/IMDS `validateOutboundEndpoint()` .
- **C05.2, C05.3 & C05.4 Auth/IAM:** Revocación de `roles/viewer` en `aegis-runner-sa` , `crypto.timingSafeEqual` , Firebase ID token y ACLs `ownerUid` .
- **C08.1 & C08.4 RAG y Evaluación:** Pre-filtrado ACL por dominio, Vertex Evaluation Service (AutoSxS) y Model Monitoring (skew/drift).
- **C09.4 & C10.1–C10.5 Agentes/MCP:** `runCompensatingSaga()` , firma MCP Ed25519/HMAC, OAuth 2.1 PKCE y `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` y alertas SOC en tiempo real vía SCC AI.

Controles de Gobernanza AIMS ISO/IEC 42001:2023 (18 Cláusulas y Anexo A)

- **Cláusula 4.1 & 4.2 Contexto y Stakeholders:** Matriz de cuestiones internas/externas, rol de proveedor de aseguramiento IA y partes interesadas.
- **Cláusula 5.1, 5.2, A.2.1 & A.2.3 Liderazgo y Política IA:** Política Corporativa de IA aprobada por dirección con revisión anual.
- **Cláusula 7.2, 7.3 & A.3.3 Competencia y Canal Ético:** Capacitación por rol y canal confidencial de denuncias (`ai-ethics-whistleblower@aegisai.enterprise`).
- **A.4.1, A.6.1.2 y A.7.3 Activos y Cadena de Suministro IA:** Catálogo de modelos verificados y firmados vía Model Garden y Model Registry.
- **A.5.1–A.5.3 y A.6.2.6 Impacto, Apelación y Seguridad:** Metodología AIIA, canal de apelación humana, Model Armor y Vertex AI Model Monitoring.
- **Cláusula 9.1–9.3, A.6.2.4 y A.6.2.8 Evaluación y SOC:** Pista de auditoría Vertex Evaluation (AutoSxS), auditorías internas y alertas SCC AI.

EVOLUCIÓN Y ROADMAP

Siguientes Pasos en la Ingeniería de AegisAI

Hoja de ruta para consolidar el aseguramiento autónomo de Inteligencia Artificial empresarial.

Q4 2026 • CORTO PLAZO

Compuertas CI/CD Shift-Left

GitHub Actions y **GitLab CI Runners** oficiales para bloquear automáticamente *pull requests* con vulnerabilidades de prompt injection, manifiestos MCP sin firma o vectores sin cifrar.

Q1 2027 • MEDIANO PLAZO

Auditoría de Grafos Multi-Agente

Módulo especializado para auditar flujos de agentes autónomos complejos (LangGraph, CrewAI, AutoGen): validación de fronteras de autorización, sagas compensatorias y sandboxing de memoria.

Q2 2027 • LARGO PLAZO

Auto-Remediación con IaC

Síntesis automatizada de módulos de **Terraform** y **Helm Charts** que apliquen políticas de Cloud IAP, VPC Service Controls y Model Armor en un clic.

🎯 Conclusión: Seguridad y Gobernanza que Aceleran la Innovación

AegisAI proporciona la **certeza arquitectónica, integridad criptográfica y el Stack de Protección IA de Google Cloud en 3 Fases (ISO/IEC 42001)** necesarios para que las organizaciones desplieguen sistemas de IA con confianza total.

Contacto: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI